

Lecture 57 : The NMAP Tool: A Relook (Part II)

Introduction

In the intricate landscape of network security, understanding the services running on target machines is a foundational step for both defenders and ethical hackers. Just as a detective surveys a building for entry points, a network professional uses tools like NMAP to discover open "doors" – or ports – on a system. These ports are the digital interfaces through which services like web servers, email servers, or remote access tools communicate, and their status (open, closed, or filtered) can reveal critical information about a system's vulnerabilities.

This lecture delves into the advanced port scanning capabilities of NMAP, building upon previous discussions of host discovery. We explore various techniques, from the straightforward TCP Connect scan to more sophisticated stealth methods, each designed to elicit specific responses from a target while managing detectability. Mastering these techniques is crucial for accurately mapping a network's attack surface and identifying potential weaknesses that could be exploited.

Core Concepts

Term	Definition	Significance
Port Scanning	The process of systematically probing a target host's ports to determine their state (open, closed, or filtered) and identify running services.	Essential for discovering potential entry points and understanding the services exposed by a target system.
TCP 3-way Handshake	The standard connection establishment procedure for TCP, involving SYN, SYN/ACK, and ACK packets exchanged between client and server.	Forms the basis for several TCP-based NMAP scans, determining if a service is actively listening on a port.
TCP Connect Scan (-sT)	An NMAP scan that attempts to complete the full TCP 3-way handshake with each target port.	Reliable for identifying open ports but easily detectable by system administrators as

Term	Definition	Significance
		it creates full connection logs.
TCP SYN Scan (-sS)	Also known as "half-open scanning," this technique sends a SYN packet, expects a SYN/ACK, but then sends a RST instead of completing the handshake with an ACK.	Faster and less detectable than a Connect scan because it avoids creating full connection logs on the target system.
TCP Stealth Scan	A category of scans designed to evade detection by firewalls and Intrusion Detection Systems (IDS) by sending "wrong" or unusual TCP packets.	Aims to gather port state information without leaving significant traces or triggering security alerts.
FTP Bounce Scan (-b)	A technique that uses an intermediate FTP server to relay scan requests to a target, effectively masking the scanner's true origin.	Can bypass some firewall rules and obscure the source of the scan, making it harder to trace.
RFC 793	A Request for Comments document that specifies the Transmission Control Protocol (TCP) and includes guidelines for how hosts should handle various TCP packets, including "wrong" ones.	Provides the theoretical foundation for certain stealth scanning techniques by defining expected responses to non-standard packets.
Fast Mode (-F)	An NMAP option that instructs the scanner to only scan a limited number of the most common ports, rather than all 65535 ports.	Significantly speeds up the scanning process when a comprehensive scan is not immediately required.
--top-ports <number>	An NMAP option to scan a specified quantity of the most commonly used ports, ranked by NMAP's internal database.	Efficiently targets high-probability services, useful for quick assessments of common vulnerabilities.

Term	Definition	Significance
IP Protocol Scan (-s0)	An NMAP scan that identifies which IP protocols (e.g., ICMP, TCP, UDP) are supported and open on a target host, rather than specific port numbers.	Provides a different layer of network discovery, revealing protocol-level services that might not be tied to a specific port.

Detailed Analysis

1. TCP Connect Scan and TCP SYN Scan

Port scanning is fundamentally about determining if a service is listening on a particular port. For TCP services, this often involves leveraging the TCP 3-way handshake.

- **TCP Connect Scan (-sT):**
 - This is the most basic and straightforward TCP scan.
 - The scanner initiates a full TCP 3-way handshake:
 - Scanner sends a `SYN` packet to the target port.
 - If the port is open and a service is listening, the target responds with a `SYN/ACK` packet.
 - The scanner then completes the handshake by sending an `ACK` packet.
 - Conclusion: The port is open.
 - If the port is closed, the target responds with a `RST/ACK` packet, indicating termination.
 - Conclusion: The port is closed.
- **Detectability:** This scan is easily detectable because it completes the full connection, which is typically logged by the operating system and network security devices. System administrators can readily spot these connection attempts in their logs.
- **NMAP Example:**

```
nmap -sT <target_ip> -p 22
```

This command would attempt a TCP Connect scan on port 22 of the specified target. If the port is closed, NMAP would report it as such. If open, it would report the service. The lecture provides an example where port 22 is closed, and another

where port 135 is open. Using the `--packet-trace` option provides detailed packet information:

```
nmap -sT --packet-trace <target_ip> -p 22
```

This shows the sent and received packets, helping to understand NMAP's conclusion.

- **TCP SYN Scan (`-sS`):**

- Also known as "half-open scanning" or "stealth scan" (though not as stealthy as true stealth scans).
- It utilizes the initial two steps of the TCP 3-way handshake but does not complete the connection.
- The scanner sends a `SYN` packet.
- If the port is open, the target responds with a `SYN/ACK`.
- Instead of sending an `ACK` to complete the handshake, the scanner immediately sends a `RST` (reset) packet to terminate the connection.
- Conclusion: The port is open.
- If the port is closed, the target responds with a `RST/ACK` packet.
- Conclusion: The port is closed.
- **Detectability:** This method is less detectable than the TCP Connect scan because it does not establish a full connection, thus often avoiding logging by the target's operating system. However, modern Intrusion Detection Systems (IDS) can still detect half-open connections.

2. TCP Stealth Scan

True TCP stealth scans aim to avoid detection by firewalls and IDS by sending "wrong" or unusual packets, relying on the target's TCP/IP stack implementation (often based on RFCs) to infer port states.

- **Mechanism:**

- The core idea is to hide scanning packets within normal network traffic or to send packets that appear harmless.
- These scans often use an "inverse mapping" approach: a response is expected only if the port is closed. If the port is open, the "wrong" packet is ignored, and no response is sent back.
- **RFC 793:** This document specifies how a host should handle various TCP packets. Stealth scans exploit these specifications. For example, if a scanner

sends a **FIN** (finish) or **RST** (reset) packet to a port without an established connection:

- If the port is **open**, the target's TCP stack, according to RFC 793, should ignore the unexpected packet and send no response.
- If the port is **closed**, the target should respond with a **RST/ACK** packet, indicating that it wants to terminate a non-existent connection.
- **Conclusion:**
 - No response from the target implies the port is **open**.
 - A **RST/ACK** response implies the port is **closed**.
- **Detectability:** These scans are difficult to detect because they don't trigger typical connection logging. They send packets infrequently and in ways that might be overlooked by basic IDS/firewall rules. Examples include:
 - **Null Scan (-sN):** Sends TCP packets with no flags set.
 - **FIN Scan (-sF):** Sends TCP packets with only the **FIN** flag set.
 - **Xmas Scan (-sX):** Sends TCP packets with **FIN** , **PSH** , and **URG** flags set (like a "Christmas tree" with all lights on), hoping it will be seen as important and allowed through.

3. FTP Bounce Scan

This technique leverages an intermediate FTP server to perform the scan, effectively bouncing the scan off the FTP server to the actual target.

- **Mechanism:**
 - The scanner establishes a control connection (port 21) with a vulnerable FTP server.
 - The scanner then instructs the FTP server to initiate a data transfer connection (port 22) to a different target IP address and port, spoofing the target's IP address in the request.
 - The FTP server, believing it's fulfilling a legitimate data transfer request, sends a **SYN** packet to the actual target.
 - The target responds to the FTP server (e.g., with a **RST** if the port is closed).
 - The FTP server then reports the success or failure of the data connection attempt back to the original scanner.
- **Conclusion:** By observing the FTP server's response, the scanner can infer the state of the target port.

- **Significance:** This method can bypass firewalls that trust the FTP server and can obscure the true origin of the scan, making it appear as if the FTP server is the source of the activity.
- **NMAP Option:** `-b`

4. NMAP Port Specification and Scan Order Options

NMAP offers extensive control over which ports are scanned and in what order.

- **Specifying Ports (`-p`):**
 - Scan a single port: `nmap -p 22 <target_ip>`
 - Scan a range of ports: `nmap -p 1-100 <target_ip>`
 - Scan specific ports: `nmap -p 22,80,443 <target_ip>`
 - Scan a combination of TCP and UDP ports:
`nmap -p U:53,161,T:21-25,80,443 <target_ip>` (U for UDP, T for TCP)
- **Fast Mode (`-F`):**
 - Scans a limited number of the most common ports (typically the top 100).
 - Speeds up the scanning process significantly compared to scanning all 65535 ports.
 - Example: `nmap -F <target_ip>`
- **Top Ports (`--top-ports <number>`):**
 - Scans a specified number of the most commonly used ports based on NMAP's internal database.
 - Example: `nmap --top-ports 3 <target_ip>` (scans the 3 most common ports like Telnet, HTTP, HTTPS).
- **Scan Order (`-r`):**
 - By default, NMAP randomizes the port scan order to avoid detection by some security systems.
 - The `-r` option forces NMAP to scan ports consecutively (in numerical order).

5. IP Protocol Scan (`-s0`)

Unlike other scans that target specific port numbers, the IP Protocol Scan identifies which IP protocols are supported by the target host.

- **Mechanism:**

- NMAP sends raw IP packets without a port number, attempting to elicit responses for different IP protocol numbers (e.g., 1 for ICMP, 6 for TCP, 17 for UDP).
- **Conclusion:** The scan reports which protocols are "open" (meaning the host responds to packets for that protocol) or "filtered" (meaning a firewall might be blocking it).
- **Significance:** This scan provides information at a lower layer of the network stack, revealing services that might not be associated with a traditional TCP/UDP port, such as ICMP.
- **NMAP Example:** `nmap -s0 <target_ip>`

Key Takeaways

- [] NMAP offers diverse port scanning techniques, each with varying levels of speed, reliability, and detectability.
- [] TCP Connect Scan (`-sT`) completes the 3-way handshake, making it reliable but easily logged and detected.
- [] TCP SYN Scan (`-sS`) is a "half-open" scan that avoids full connection logging, offering a balance of speed and stealth.
- [] TCP Stealth Scans (e.g., Null, FIN, Xmas) exploit RFC specifications to infer port states by sending "wrong" packets, aiming to evade IDS/firewalls.
- [] FTP Bounce Scan (`-b`) uses an intermediate FTP server to proxy scan requests, masking the scanner's origin.
- [] NMAP provides flexible options for specifying ports, including ranges (`-p 1-100`), specific lists (`-p 22,80`), and protocol-specific ports (`-p U:53,T:80`).
- [] Fast Mode (`-F`) and `--top-ports` options allow for quicker scans by targeting only the most common or specified number of ports.
- [] IP Protocol Scan (`-s0`) identifies open IP protocols (like ICMP, TCP, UDP) rather than specific port numbers, offering a different perspective on host services.
- [] The choice of scanning technique depends on the objective: reliability, speed, or stealth.

Conclusion

The ability to effectively scan and identify open ports and running services is a cornerstone of network security and ethical hacking. NMAP's comprehensive suite of port scanning options empowers users to meticulously map the attack surface of any target system. By understanding the nuances of each scan type – from the overt

TCP Connect scan to the covert TCP Stealth and FTP Bounce scans – professionals can choose the most appropriate method for their objectives, whether it's a quick assessment or a deep, evasive reconnaissance mission.

This detailed exploration of NMAP's port scanning capabilities highlights its indispensable role in vulnerability assessment. Knowing which services are active on a host is the first step toward identifying potential vulnerabilities and planning subsequent exploitation attempts. As we move forward, these port discovery skills will serve as a critical foundation for further NMAP functionalities, such as operating system detection and service version enumeration, ultimately contributing to a more complete understanding of a target's security posture.